

SMART INDIA HACKATHON 2025

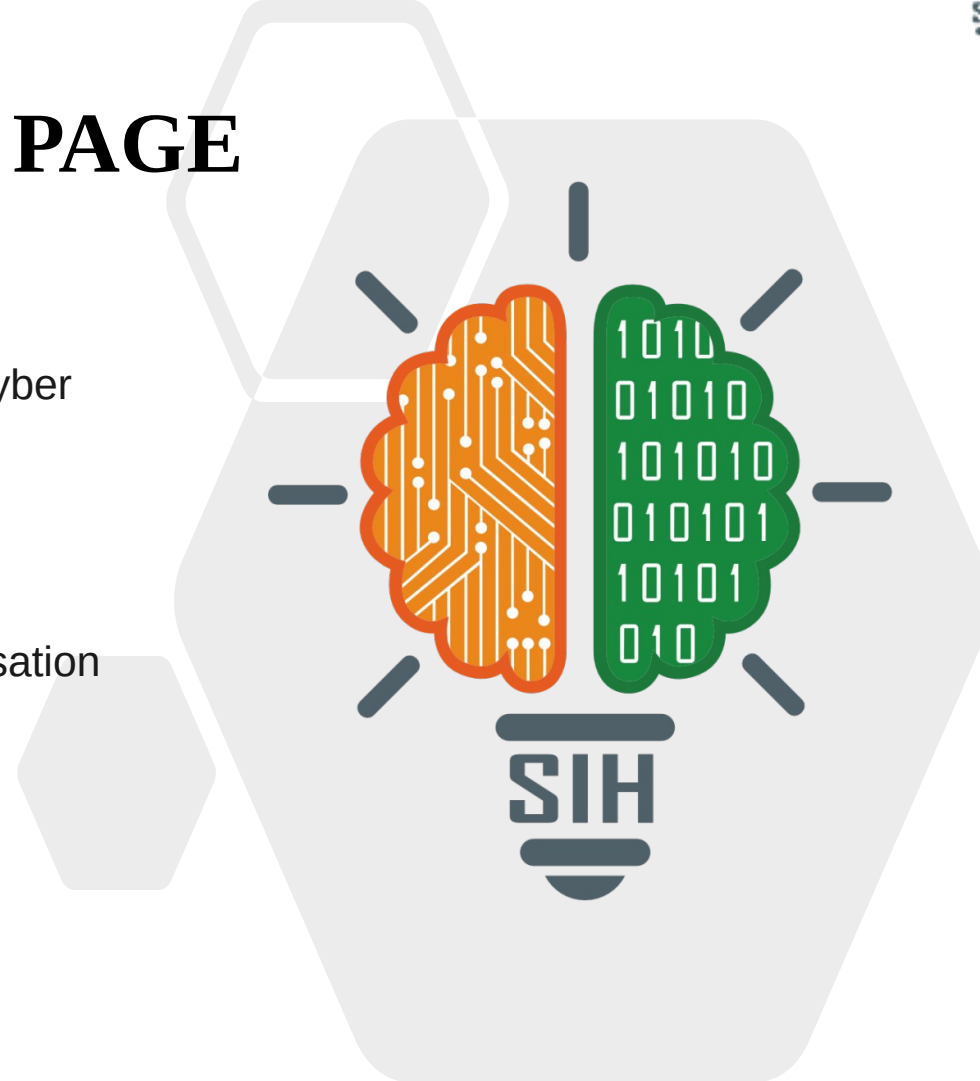


TITLE PAGE

- **Problem Statement ID** — SIH26145
- **Problem Statement Title** — AI-Based Detection of Cyber Threats in Unidirectional IP Traffic
- **Theme** — Blockchain & Cybersecurity
- **PS Category** — Software
- **Organisation** — National Technical Research Organisation (NTRO)
- **Team ID** —
- **Team Name** — Forward Bias

Code — github.com/utsavagg2007/SIH-2026

Live demo — sih-2026-three-rosy.vercel.app



IDEA TITLE

Passive, evidence-first threat detection for receive-only network taps

A sensor that watches a one-way mirrored copy of gateway traffic and can never transmit back.

Proposed Solution

- **Pipeline** — PCAP / NetFlow → Zeek → Rust feature core → 7 detectors → fusion → alert bus → dashboard + AI analyst.
- **Coverage** — port scan, DDoS, C2 beaconing, DNS tunnelling, DGA, encrypted malware, data exfiltration — each mapped to MITRE ATT&CK.
- **Output** — one frozen alert contract (ThreatAlert v1.1) carrying a calibrated confidence score, severity and evidence.

How it addresses the problem

- **Encrypted traffic, no decryption** — JA3 / JA3S / JA4 handshake fingerprints, SNI, packet and byte timing. No key is ever held.
- **Streaming, not batch** — alerts reach the screen before they reach the database; the live path never waits on the durable one.

Innovation and uniqueness

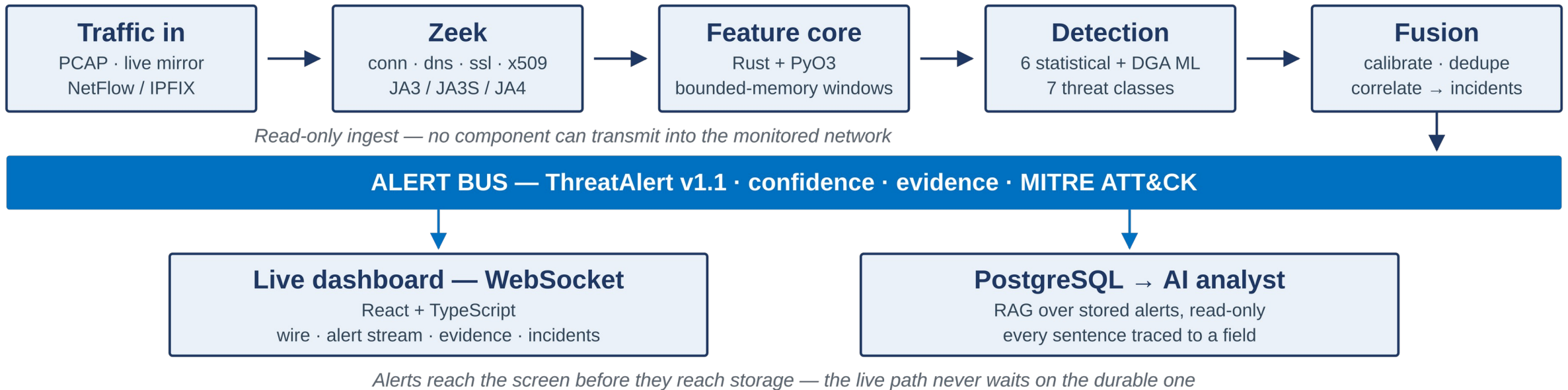
- **Evidence, not verdicts** — every alert names the features that fired and the thresholds they crossed.
- **Fusion layer** — sixty repeat beacons collapse into one correlated incident that walks the kill chain.
- **Read-only is proven, not claimed** — a live endpoint walks the running route table to show no path out exists.
- **The AI analyst is verified** — any figure it states that no stored field supports is discarded, not published.

TECHNICAL APPROACH

Technologies used

- **Capture & parse** — Zeek (JSON logs, JA3/JA3S/JA4), Docker-pinned runtime
- **Feature core** — Rust + PyO3 — stateful windowed aggregation
- **Detection** — Python 3.12, scikit-learn DGA classifier
- **Backend** — FastAPI, WebSocket alert bus, asyncpg
- **Storage** — PostgreSQL / Supabase, in-memory fallback
- **Dashboard & analyst** — React 18 + TypeScript + Vite; RAG analyst

Methodology — implementation flow



FEASIBILITY AND VIABILITY



Feasibility

- **Already built, end to end.** Nine layers run today — 2,398 passing tests plus 30 cross-layer checks over the seams between them.
- **Commodity hardware.** 13,012 flows/sec through detection; the backend sustains 500 alerts/sec at p95 under 200 ms.
- **No licence cost.** Zeek, FastAPI, React and scikit-learn — open source throughout, deployable per sensor at zero marginal cost.
- **Reproducible by design.** Replay is deterministic — the same capture always yields the same alerts, so every figure here can be re-run.
- **Deploys where it must.** Runs wholly inside the enclave; the language model is optional and off by default.

Risks, and what we did about them

- **False positives on real traffic.** Measured on 1.9 M real flows (CIC-IDS2017, UNSW-NB15): rebuilt two detectors, alerts fell 1,797 → 267 (−85%) with recall unchanged.
- **ML flagging benign CDN names.** Added 1,824 real CDN and object-storage hostnames to the corpus — DGA precision 0.17 → 1.00.
- **Payload is unreadable.** Scored on handshake metadata and timing, never plaintext.
- **Language models invent numbers.** Ungrounded output is discarded and the deterministic explanation returned instead.
- **Analyst offline.** Detection is unaffected — the AI layer is off the critical path by design.

IMPACT AND BENEFITS



Impact on the target audience

- **Sight where there was none.** Threat detection inside one-way and air-gapped enclaves, where inline IDS and TLS interception cannot be deployed at all.
- **A queue an analyst can work.** 85% fewer false alarms and repeats collapsed into incidents — attention goes to the real thing.
- **Triage in seconds.** Each alert arrives with its evidence and a plain-language explanation, so no one reconstructs the reasoning by hand.
- **Evidence outlives the shift.** Alerts persist with their evidence, so an incident can be reconstructed later, not only watched live.

Benefits of the solution

- **Security.** Seven threat classes, MITRE ATT&CK mapped, confidence-scored.
- **Operational.** Alerts on screen before storage; failures degrade visibly, never silently.
- **Economic.** Open-source stack on commodity hardware — no per-sensor licence.
- **Strategic.** A sovereign, offline-capable capability; nothing leaves the enclave.
- **Trust.** Every claim traces to a stored field; the read-only posture is verifiable while it runs.

7

threat classes

13,012

flows / sec

–85%

false positives

2,398

passing tests

RESEARCH AND REFERENCES



Standards and frameworks

- **Zeek Network Security Monitor** — docs.zeek.org
- **MITRE ATT&CK** — T1046, T1071.001, T1048, T1568.002, T1572 — attack.mitre.org
- **JA3 / JA3S** (Salesforce) and JA4+ (FoxIO) TLS fingerprinting
- **RFC 3954 (NetFlow v9), RFC 7011 (IPFIX)** — flow-record ingest path

Datasets used for evaluation

- **CIC-IDS2017** — Canadian Institute for Cybersecurity, UNB — 2.83 M labelled real flows
- **UNSW-NB15** — ACCS, Zenodo record 10140548 — 700 k real flows
- **Tranco Top-1M** and Cisco Umbrella Top-1M — benign domain corpus
- **DGA family corpus** — github.com/baderj/domain_generation_algorithms

Our own evaluation record, published in the repository

- **REAL_DATA_EVAL.md** — false positives on 1.9 M real flows, including what we measured and rejected
- **DGA_PRECISION.md** — corpus construction and every threshold sweep behind the 0.65 decision point
- **threat_alert_v1.1.md** — the frozen alert contract, with its freeze checklist as executable tests

Code — github.com/utsavagg2007/SIH-2026

Live demo — sih-2026-three-rosy.vercel.app

Every figure quoted in this deck is reproducible from the repository — tools/evaluate.py, backend/tools/benchmark.py, tools/verify_e2e.py.